

YohPal Live: what shipped, what didn't

A finding-by-finding re-audit of the codebase against every Critical, High, Medium, and Low issue raised in docs/PRODUCTION_READINESS_REVIEW.html, verified fresh against current source — not against memory of what was worked on.

Baseline Production Readiness Review, 2026-07-09 **Status as of** 2026-07-10

Method git log + targeted re-grep of every original finding

Scope executed Release Track 1.0B (money/security) + ad hoc auth work

01 Executive summary

Of the original review's 40 findings, **7 are fully closed and 3 are partially mitigated** — concentrated almost entirely in the Critical, money-and-fraud bucket, which was the right thing to fix first. The High-severity bucket, which is mostly UX reliability and test coverage, is essentially untouched: **0 of 13 fully fixed**. Two features not in the original review at all — Google and Apple Sign-In — were built from scratch this cycle.

4/9 Critical fixed	1/9 Critical mitigated	0/13 High fixed	1/14 Medium fixed	1/4 Low fixed
2 Net-new features (SSO)				

The work that happened maps almost exactly to one branch of the release plan the team wrote in response to the review ([apps/mobile_flutter/docs/](#)): **Track 1.0B — Money, Security & Wallet Reconciliation** was executed in full. Tracks 1.0A (account/navigation/observability), 1.0C (feed/live UX recovery), and 1.0D (cleanup/tests/release gate) were not started, with one exception — sign-out, which was technically scoped under 1.0A, got built as a standalone request and is done. On top of that plan, a second wave of work went well beyond it: Google and Apple SSO, a full login/signup visual redesign, and a Terms & Conditions requirement — none of which were asked for by the original review, but which materially improve the auth surface anyway.

The net effect: **the fraud-and-money risk this app carried is substantially reduced** — gift amounts are now server-validated, rewarded-ad spoofing has a real mitigation, Firestore's most exploitable write rules are closed, and users finally get feedback when a wallet action completes. But the app is **no closer to General Availability than the original review's headline blockers imply** — the crashing Analytics route, the complete absence of crash reporting, hardcoded production infrastructure, and password reset are all still exactly as they were found. Anyone reading only "9 Critical → 4 fixed" without reading which 4 would over-estimate readiness.

02 Authentication: full progress

Requested separately because more happened here than anywhere else in the codebase this cycle. Organized by what's real and working versus what's still exactly as the original review found it.

Shipped and verified working

Sign-out — Critical finding #1, closed

creator_profile_screen.dart · _LogoutButton

Confirm dialog → `AuthController.logout()` → pops the nav stack to root so `AuthGate`'s reactive swap to `LoginScreen` is actually visible, not hidden under a pushed route. This was previously implemented but fully unreachable — `logout()` existed with zero call sites anywhere in the UI.

Google Sign-In — new capability

auth_repository.dart · `signInWithGoogle()`

Real credential exchange via `google_sign_in` + Firebase's `GoogleAuthProvider`, not a stub. Creates `users` / `creatorProfiles` Firestore docs only when Firebase reports a genuinely new account, so a returning Google user is treated as login, not signup.

Apple Sign-In — new capability

auth_repository.dart · `signInWithApple()`

Nonce-secured per Apple/Firebase's required flow. Apple only ever returns the user's name on their very first authorization ever — that's captured and saved immediately, since it's unrecoverable after. Hidden on Android in the UI, where `sign_in_with_apple` has no native support without server-side relay infrastructure this project doesn't have.

A regression was introduced, then caught and fixed in the same cycle

auth_repository.dart · `signOut()`

Adding Google sign-out to `signOut()` put it *before* the real Firebase sign-out call — if the Google call threw for any user who'd never used Google Sign-In, Firebase sign-out never ran, and logout silently stopped working end to end. Fixed by making the Google cleanup best-effort and non-blocking; Firebase sign-out now always executes regardless.

Terms & Conditions — partially closes High finding #1

signup_screen.dart, terms_and_conditions_screen.dart

A real, readable Terms page, gated behind a required checkbox before account creation — the original "no ToS/Privacy link" gap is now half-closed (ToS exists; there's still no separate Privacy Policy link).

Confirm-password field — Low finding, closed

signup_screen.dart

With an actual mismatch check on submit, not a decorative field.

First/last name split, full visual redesign

login_screen.dart, signup_screen.dart

Display name is now first + last name, joined for the backend call. Both screens moved off a boxed card onto a full-bleed background with a shared brand mark and SSO tile row, for visual consistency with each other.

Still exactly as the original review found it

GAP	SEVERITY	CURRENT STATE
Password reset	CRITICAL	"Forgot password?" exists on the login screen and is tappable, but it only shows a "coming soon" message. No <code>sendPasswordResetEmail</code> call anywhere in the codebase.
Email verification	HIGH	Not implemented for any signup path, including the two new SSO paths.
Client-side input validation	HIGH	Login still has no <code>Form</code> /validators at all. Signup validates password-match and terms-acceptance, but not email format or field emptiness before hitting Firebase.
Friendly error messages	HIGH	Raw Firebase exception strings are still shown verbatim (e.g. <code>[firebase_auth/invalid-credential] ...</code>). The <code>AuthErrorMapper</code> class proposed in the team's own 1.0A release patch was never built.
Cross-account state clearing on logout	HIGH	<code>logout()</code> still only calls <code>signOut()</code> — no explicit cache clear for feed/wallet/notification token. Real-world risk is lower than the finding implies, since most screens are Firestore-stream-driven and re-key by uid, but it's not addressed as stated.

Unverified, not just unfinished: the SSO implementation has not been exercised on a real device or simulator from this environment — no way to confirm the OAuth round-trip actually completes end to end. It also depends on two things outside the codebase entirely: Google and Apple must be turned on as enabled sign-in providers in the Firebase console, and "Sign in with Apple" must be enabled for the App ID in the Apple Developer portal. Neither can be confirmed from source.

03 **Critical findings — 4 fixed, 1 mitigated, 4 open**

FINDING	STATUS	EVIDENCE
No sign-out control anywhere in the UI	Fixed	<code>creator_profile_screen.dart</code> — see §2
Profile → Analytics crashes on a hardcoded wrong route string	Open	<code>profile_hub_screen.dart:100</code> still pushes <code>/creator-analytics</code> ; registered route is <code>/creator-profile/analytics</code> . No <code>onUnknownRoute</code> fallback exists. Unchanged.
No crash reporting or global error boundary	Open	<code>main.dart</code> has no <code>runZonedGuarded</code> / <code>FlutterError.onError</code> . No Crashlytics/Sentry dependency in <code>pubspec.yaml</code> . Unchanged.
No password reset / account recovery	Open	See §2 — stub only.
Rewarded-ads reward crediting is spoofable (no ad SDK)	Mitigated	<code>rewardedAdProcessor.ts</code> now requires real elapsed time between a <code>view_start</code> and tier-completion event before crediting. Real fix still needs an actual ad-network SDK with server-side verification (e.g. AdMob SSV) — not present.
Firestore <code>gifts</code> subcollection: client sets its own monetary amount	Fixed	<code>firestore.rules</code> : <code>gifts</code> create/update/delete now <code>if false</code> . New <code>validatedGiftPurchase</code> Cloud Function validates against a server-side catalog and debits the sender's real wallet balance before writing the gift doc.
Every money flow has zero reconciliation UX — <code>WalletStatusScreen</code> is an unbuilt placeholder	Fixed	Real <code>WalletStatusScreen</code> , registered route, plus a <code>yohpal://wallet-status</code> deep link so returning from the external wallet checkout actually lands somewhere.
Production infrastructure URLs hardcoded, no environment split	Open	<code>app.dart</code> still hardcodes <code>https://us-central1-yohlab.cloudfunctions.net</code> three times; <code>yohpal_web_handoff.dart</code> still hardcodes the wallet/ads/subscriptions web domains. No <code>--dart-define</code> config exists. Unchanged.
<code>videoStats</code> / <code>referralEvents</code> Firestore rules allow unrestricted or unauthenticated writes	Fixed	<code>videoStats</code> now requires the exact field set the real client write uses. <code>referralEvents</code> now requires auth

FINDING	STATUS	EVIDENCE
		+ ownership (client updated to stamp <code>userId</code> so the rule has something to check).

04 High findings — 0 fixed, 1 partial, 12 open

This is the bucket that didn't get touched. All of it maps to Release Tracks 1.0A (the rest of it), 1.0C, and 1.0D in the team's own plan, none of which were executed this cycle.

FINDING	STATUS	NOTE
No client validation / ToS link / email verification on signup	Partial	ToS added (see §2); validation and email verification still absent.
Raw Firebase exception strings shown to users	Open	See §2.
Live streaming has no reconnect/timeout handling	Open	No LiveKit <code>RoomEvent</code> /connection-state listener found in <code>live_stream_controller.dart</code> .
Search is fully built, zero navigation entry point	Open	No reference to <code>SearchScreen</code> / <code>AppRoutes.search</code> in any hub screen.
Live Discovery is fully built, zero navigation entry point	Open	No reference to <code>AppRoutes.live</code> in any hub screen.
Feed error state has no retry	Open	Unaudited this cycle but no commits touched <code>video_feed_screen.dart</code> .
AI publish checklist doesn't gate publishing	Open	<code>aiPublishStatus</code> is still written in exactly one place and read in zero.
Zero accessibility semantics on the feed/engagement rail	Open	No <code>Semantics()</code> usage found anywhere in <code>video_feed</code> , <code>video_playback</code> , or <code>engagement</code> .
Only 4 test files in the repo	Open	Still exactly 4 — <code>widget_test.dart</code> plus 3 old phase tests. No tests were added for the gift-purchase Cloud Function, wallet reconciliation, or either SSO path, despite all being new, money-and-auth-adjacent code.
Duplicate/overlapping video-pipeline implementations	Open	<code>lib/core/video/</code> and <code>lib/core/video_feed/</code> both still present, unreferenced.
Avatar upload is a raw URL text field, not real upload	Open	<code>edit_creator_profile_screen.dart</code> still reads "Temporary — Storage upload comes in a future phase."
Chat send failures aren't caught / surfaced	Open	<code>chat_room_screen.dart</code> has a <code>try/finally</code> around send (resets the

FINDING	STATUS	NOTE
		loading flag) but still no catch — a failed send gives the user no feedback.
Logout doesn't clear cross-account cached state	Open	See §2.

05 **Medium findings — 1 fixed, 13 open**

FINDING	STATUS	NOTE
Any signed-in user could edit another user's live-session counters	Fixed	<code>firestore.rules</code> : <code>giftTotal</code> removed from the client-editable diff on <code>liveSessions</code> ; only <code>viewerCount</code> remains, and only <code>validatedGiftPurchase</code> (Admin SDK) moves <code>giftTotal</code> now.
No mute/unmute on video feed	Open	—
No double-tap-to-like / long-press	Open	—
Feed hard-capped at 100 items, no pagination	Open	—
Notification handling while backgrounded is a bare stub	Open	—
Typing indicators are backend-only	Open	—
Chat has no pagination or media messages	Open	—
Video upload: no camera capture, no cancel/retry, no connectivity pre-check	Open	—
"AI Invite Ranker" is a hardcoded heuristic, not AI	Open	—
Gift-sending drops the user's tier selection before web handoff	Open	This refers to <code>gift_creator_screen.dart</code> (the "tip a creator" web-handoff flow) — a different screen from the live-stream gift panel that was fixed this cycle. Not the same gap.
Create hub's "Multistream Setup"/"Live Commerce Setup" are mislabeled duplicates of Go Live	Open	—
<code>livekit_client</code> pinned to a single-patch-version range	Open	Still <code>">=2.3.0 <2.3.2"</code> in <code>pubspec.yaml</code> .
Analytics/telemetry scattered, no shared taxonomy	Open	—

FINDING	STATUS	NOTE
Video controller leak on fast-scroll	Open	—

06 Low findings — 1 fixed, 3 open

FINDING	STATUS	NOTE
No confirm-password field on signup	Fixed	See §2.
Creator Analytics shows only 3 static numbers, no charts	Open	—
"Coming soon" stubs indistinguishable from working entries	Open	Login's "Forgot password?" and both SSO tiles are new instances of this same pattern — they look identical to fully working buttons.
Dead code: <code>ChatSdkAdapter</code> , <code>MessageBubble</code> , <code>MonetisationService</code> , <code>WalletLauncherService</code> , etc.	Open	None of the originally-listed dead code was removed. One additional dead method (<code>LiveGiftRepository.sendGift</code>) was retired as a side effect of the gift-flow migration — not in the original list, a bonus cleanup.

07 Work done beyond the original review

Not findings from the audit — new capabilities and one bug the audit didn't have visibility into, since it never inspected the Cloud Functions backend.

- **Google + Apple SSO**, described fully in §2.
- **A real backend bug, found and fixed:** `mpesaPayoutTrigger.ts` was reading and writing a `wallets/{uid}` collection that nothing else in the codebase ever populated — every real balance lives in `walletBalances/{uid}`. Every payout request was silently failing "insufficient balance" regardless of a creator's actual balance. Repointed to the correct collection.
- **Login/signup visual redesign:** both screens moved off a boxed card onto a full-bleed themed background, added a shared brand mark, an "or continue with" divider, and the SSO tile row — a UX pass, not a functional fix.
- **Display name split into first/last name** on signup.

08 What to prioritize next

In order — each depends less on the ones after it than the reverse.

1. **Crash reporting.** Nothing else on this list will be observable in production without it, and it's the smallest remaining Critical item.
2. **Fix the Analytics route crash.** A one-line fix (`profile_hub_screen.dart:100`) sitting on one of five primary navigation destinations.
3. **Password reset.** The button already exists and is discoverable — it just doesn't do anything yet. This is now the most visible remaining gap in the auth flow this cycle's work built out.
4. **Friendly auth error messages.** Small, contained, and was already scoped and half-designed in the team's own 1.0A plan — never built.
5. **Environment config for hardcoded URLs.** Blocks safely rotating infrastructure without an app-store release, and blocks having a real staging environment at all.
6. **Wire Search and Live Discovery into navigation.** Both backends already work — this is the highest user-value-per-hour item left on the entire original list.
7. **Add test coverage for what just shipped.** The gift-purchase Cloud Function, wallet reconciliation flow, and both SSO paths are new, money- and auth-adjacent, and currently have zero automated coverage.

YohPal Live — Implementation Status Report, verified against HEAD on 2026-07-10 via fresh re-grep of every finding in the original Production Readiness Review, not from memory of prior work in this thread. Re-verify file:line citations against current HEAD before acting on them if further commits have landed since.